VEILLE TECHNOLOGIQUE

VPN vs ZTNA

Transition vers un accès réseau Zero Trust

— Appliqué au contexte de la Maison des Ligues de Lorraine —

Contexte de l'étude

La Maison des Ligues de Lorraine (M2L) est un établissement du Conseil Régional hébergeant 24 ligues sportives dans 4 bâtiments interconnectés. Face à un réseau actuellement unifié (172.16.0.0/16), à un accès Intranet/Extranet ouvert aux ligues depuis l'extérieur, et à un projet de segmentation réseau en cours, la question de la sécurisation des accès distants se pose concrètement.

Mots-clés : VPN | ZTNA | Zero Trust | M2L | Segmentation réseau | Accès Extranet

Année scolaire 2024 – 2025

1. Présentation du contexte – La M2L et son infrastructure réseau

1.1 La Maison des Ligues de Lorraine

La Maison des Ligues de Lorraine (M2L) est un établissement du Conseil Régional, dont la gestion est déléguée au Comité Régional Olympique et Sportif de Lorraine (CROSL). Elle héberge 24 ligues sportives régionales ainsi que des comités départementaux dans un complexe de 4 bâtiments (A, B, C et D), représentant 80 bureaux au total.

Chiffres clés de la M2L

- 4 bâtiments : A & C (4 étages + RDC), B & D (plain-pied) — bâtiments C et D neufs (2010)
- 24 ligues sportives hébergées – de la ligue de tennis (8 salariés) à des ligues sans permanents
- 80 bureaux répartis sur les étages des bâtiments A et C
- 8 salles de réunion + 1 amphithéâtre (200 places) + 1 salle multimédia (24 postes)
- Réseau IP unique : 172.16.0.0/16 partagé entre toutes les ligues et l'administration
- DMZ : 10.54.0.0/24 — serveurs web, mail (lorraine-sport.net), gestion des configurations

1.2 L'infrastructure réseau actuelle

Le réseau de la M2L se compose actuellement de trois zones distinctes, gérées depuis la baie de brassage principale du bâtiment B :

Zone réseau	Adressage	Équipements / Services	Problématique
Réseau interne commun	172.16.0.0/16	Toutes les ligues + administration M2L, NAS, serveur fichiers/DHCP, serveur impression/antivirus	⚠️ Réseau unique non segmenté : toutes les ligues partagent le même réseau
DMZ	10.54.0.0/24	Serveur web, serveur mail lorraine-sport.net, serveur gestion des configurations	⚠️ Accessible depuis l'extérieur, point d'entrée potentiel
WiFi visiteurs	Clé WPA renouvelée	Bornes WiFi RDC + étages (quinconce), accès Internet uniquement	⚠️ Clé partagée avec toutes les ligues, renouvellement manuel
Internet	Mutualisé	Accès loué à un prestataire, partagé par toutes les ligues	❌ Aucune isolation des flux par ligue

1.3 Les accès distants actuellement en place

Plusieurs services de la M2L sont accessibles depuis l'extérieur, ce qui crée des besoins d'accès distant sécurisé non formalisés :

- Le système de réservation des salles (Intranet/Extranet) est accessible depuis Internet par les ligues et les responsables de clubs
- Le serveur FTP documentaire est accessible en intranet et depuis Internet
- Les informations digicode et clé WiFi sont disponibles via un site web accessible de l'extérieur
- Les codes d'accès à l'Intranet sont diffusés par les ligues aux responsables de clubs extérieurs

Risque identifié – Accès non sécurisé

Actuellement, aucun mécanisme de type VPN ou ZTNA n'est explicitement documenté pour sécuriser ces accès distants. Le directeur M. Sapin souligne lui-même la volonté de "surveiller et contrôler" le parc et de "cloisonner au maximum les utilisateurs dans des réseaux distincts". Ce besoin est le point de départ de cette veille technologique.

2. Les VPN Traditionnels – Fonctionnement et limites

2.1 Principe général

Un VPN (Virtual Private Network) établit un tunnel chiffré entre un client distant et un réseau d'entreprise. L'utilisateur, une fois authentifié, obtient une adresse IP interne et accède aux ressources comme s'il était physiquement sur place.

Application au contexte M2L

Scénario VPN classique à la M2L : un responsable de ligue en télétravail se connecte au concentrateur VPN de la M2L. Il reçoit une adresse en 172.16.0.0/16 et accède à tout le réseau interne : serveur de fichiers, NAS, Intranet, et... aussi aux postes et données des autres ligues hébergées.

→ C'est précisément ce risque de "tout ou rien" qui illustre la limite principale du VPN dans ce contexte multi-tenant.

2.2 Protocoles VPN pertinents pour la M2L

Protocole	Avantage	Inconvénient	Adapté M2L ?
SSL/TLS (port 443)	Passe les firewalls, facile à déployer	Accès réseau total, goulot d'étranglement	⚠️ Partiel
OpenVPN	Open-source, flexible, bien documenté	Gestion des certificats complexe pour 24 ligues	⚠️ Partiel
WireGuard	Moderne, très performant, léger	Moins de contrôle applicatif, accès réseau total	⚠️ Partiel
IPsec site-à-site	Idéal pour relier des sites physiques entre eux	Pas adapté aux accès utilisateurs distants	❌ Non

2.3 Limites critiques dans le contexte M2L

Le contexte multi-locataire de la M2L rend les limitations du VPN particulièrement problématiques :

- **Réseau commun non segmenté :** avec un VPN classique vers le 172.16.0.0/16, un utilisateur d'une ligue peut potentiellement accéder aux ressources de toutes les autres ligues
- **24 structures indépendantes :** chaque ligue est une association juridiquement distincte. L'accès croisé aux données constitue une violation de confidentialité
- **Mouvement latéral facilité :** la compromission d'un compte VPN d'une petite ligue (ex : bowling, plongée) pourrait exposer les données de la ligue de tennis (8 salariés, données sensibles RH)
- **Gestion des clés WiFi :** la clé WPA partagée avec toutes les ligues ne permet pas de tracer les connexions par structure
- **Pas de contrôle de posture :** la M2L impose une procédure d'intégration des postes (antivirus, mises à jour). Le VPN ne vérifie pas que ces conditions sont respectées avant de donner l'accès

Note sur l'intégration des postes M2L

La M2L impose une procédure d'intégration : antivirus affilié au serveur M2L, agent d'inventaire, adressage DHCP, sauvegarde FTP, mises à jour automatiques. Un VPN traditionnel ne peut pas conditionner l'accès au respect de ces critères. Le ZTNA, lui, peut vérifier la conformité de la machine avant d'autoriser la connexion.

3. Le Modèle Zero Trust

3.1 Philosophie et origine

Formalisé par John Kindervag (Forrester Research, 2010) et standardisé par le NIST (SP 800-207, 2020), le Zero Trust repose sur un principe fondateur : aucune ressource, aucun utilisateur, aucun appareil ne doit être considéré comme fiable par défaut — qu'il soit à l'intérieur ou à l'extérieur du réseau.

"Never Trust, Always Verify"

Là où le VPN dit "tu es connecté, donc tu es de confiance", le Zero Trust dit "prouve qui tu es, prouve que ton appareil est sain, et je te donne accès uniquement à ce dont tu as besoin".

3.2 Les 7 piliers du Zero Trust selon le NIST

Pilier	Description	Lien avec la M2L
Identité	Authentification forte (MFA) pour chaque accès	Les 24 ligues + administration = identités distinctes à gérer
Appareils	Vérification de la conformité avant accès	Lien direct avec la procédure d'intégration M2L (antivirus, MàJ)
Réseau	Micro-segmentation, pas de confiance implicite	Répond au projet de segmentation réseau M2L en cours
Applications	Accès applicatif, pas réseau global	Réservation salles, FTP, Intranet : accès par service, pas par réseau
Données	Classification et protection selon sensibilité	Données RH des ligues, bulletins de salaire (CRIB), données CROSL
Visibilité	Journalisation complète de toutes les activités	Contrôle de l'usage par ligue (impression, affranchissement...)
Automatisation	Décisions d'accès dynamiques basées sur le risque	Révocation automatique si un poste sort de conformité M2L

4. Le ZTNA – Zero Trust Network Access

4.1 Principe du ZTNA

Le ZTNA est l'implémentation technique du Zero Trust pour les accès réseau. Contrairement au VPN, il n'expose jamais le réseau interne : l'utilisateur accède uniquement aux applications spécifiquement autorisées, après vérification de son identité et de la conformité de son appareil.

4.2 Les deux modèles d'architecture ZTNA

Modèle	Fonctionnement	Avantage	Exemple d'application M2L
Agent-based (initié par l'agent)	Agent sur le terminal → connexion sortante vers un broker cloud sécurisé	Contrôle total de la posture de l'appareil	Postes des ligues déjà équipés d'un agent d'inventaire M2L
Service-based (initié par le service)	Connecteur léger devant chaque application, proxy sans agent côté user	Pas d'agent à déployer, idéal pour accès partenaires	Accès au système de réservation pour clubs extérieurs

4.3 Flux d'accès ZTNA adapté à la M2L

Scénario : Un secrétaire de la ligue de tennis accède au système de réservation depuis son domicile

1. L'agent ZTNA vérifie que le poste est conforme : antivirus M2L actif, OS à jour, agent d'inventaire installé.

2. L'utilisateur s'authentifie via MFA (ex : Microsoft Authenticator) → identité confirmée.

3. Le broker ZTNA consulte la politique d'accès : ligue de tennis → autorisé uniquement sur le site de réservation et le serveur FTP.

4. L'accès est accordé exclusivement à ces deux applications. Le réseau 172.16.0.0/16 n'est jamais exposé.

5. Toutes les actions sont journalisées (qui, quoi, quand, depuis quel appareil).

→ Résultat : le secrétaire accède uniquement à ce dont il a besoin. Les données des autres ligues restent inaccessibles.

5. Comparaison VPN vs ZTNA – Analyse pour la M2L

5.1 Tableau comparatif général

Critère	VPN Traditionnel	ZTNA	Enjeu M2L
Niveau d'accès	❌ Réseau entier (172.16.0.0/16)	✅ Application par application	24 ligues indépendantes à isoler
Isolation multi-tenant	❌ Non – toutes ligues sur le même réseau	✅ Sécurisé – isolation par identité	Confidentialité inter-ligues
Authentification	⚠️ Login/mot de passe souvent	✅ MFA obligatoire + contexte	Accès Extranet des clubs
Vérification de posture	❌ Absent	✅ Natif – conforme à la procédure M2L	Intégration des postes ligues
Segmentation réseau	❌ Non (réseau plat actuel M2L)	✅ Micro-segmentation native	Projet segmentation M2L en cours
Visibilité / Traçabilité	⚠️ Limitée	✅ Logs complets par ligue et par user	Facturation usage (impression, FTP...)
WiFi visiteurs	❌ Incompatible (réseau, pas app)	✅ Accès applicatif depuis le WiFi guest	Bornes WiFi M2L en quinconce
VoIP bâtiments C et D	⚠️ Partiel	✅ Accès sécurisé aux services VoIP	Téléphonie IP louée aux ligues
Prestataires extérieurs	❌ Risqué – accès réseau complet	✅ Accès limité à leur périmètre	Société infographie, gardiennage...
Coût opérationnel	⚠️ Maintenance manuelle	✅ Managé par éditeur cloud	1 informaticien bénévole seulement

5.2 Adéquation par service M2L

Service M2L	Accès actuel	VPN	ZTNA	Recommandation
Système de réservation des salles	Intranet + Internet	⚠️ Accès réseau total	✅ Accès applicatif seul	ZTNA
Serveur FTP documentaire	Intranet + Internet	⚠️ Expose tout le réseau	✅ Accès FTP uniquement	ZTNA
Digicode / Clé WiFi	Site web public	❌ Inutile (déjà public)	✅ Authentification légère	ZTNA ou portail web sécurisé
Serveur gestion des configurations	DMZ (10.54.0.0/24)	⚠️ Risque d'exposition	✅ Accès admin uniquement	ZTNA + MFA fort

Service M2L	Accès actuel	VPN	ZTNA	Recommandation
Serveur mail lorraine-sport.net	DMZ accessible Internet	❌ Non nécessaire	⚠️ Partiel (SMTP standard)	DMZ maintenue
NAS (sauvegarde ligues)	Réseau interne	⚠️ Accès à tout le NAS	✅ Accès par ligue uniquement	ZTNA obligatoire
Connexions site-à-site (bât. A↔B↔C↔D)	Réseau filaire interne	✅ IPsec (déjà en place via fibre)	⚠️ Moins pertinent	VPN IPsec maintenu
Accès clubs extérieurs (réservation)	Codes Intranet partagés	❌ Risque élevé	✅ Idéal – accès limité	ZTNA prioritaire

6. Problématiques de Sécurité Identifiées à la M2L

6.1 Le réseau plat : risque principal

La M2L dispose actuellement d'un réseau unique 172.16.0.0/16 partagé entre toutes les ligues et l'administration. Cette architecture "flat network" est un risque majeur :

Risques identifiés

- Propagation virale entre ligues (un seul po
- Accès croisé aux données (une ligue peut
- Compromission d'un compte → accès à to
- Responsabilité juridique en cas de fuite de

Ce que dit le directeur M. Sapin

"Notre objectif est de surveiller et de cont configurations les postes de M2L mais a part de cloisonner au maximum les utilisat

→ Ce projet de segmentation est exactem

6.2 La gestion des accès WiFi

Le réseau WiFi visiteurs de la M2L utilise une clé WPA partagée, renouvelée régulièrement et communiquée à toutes les ligues. Cette approche présente plusieurs failles :

- La clé est partagée avec toutes les ligues → difficulté à révoquer l'accès à une structure spécifique
- Les bornes sont positionnées en quinconce jusqu'aux étages des ligues → surface d'attaque étendue
- Aucune traçabilité des connexions par utilisateur sur le réseau WiFi guest

Solution ZTNA sur WiFi

Avec ZTNA, même connecté en WiFi (réseau non maîtrisé), l'utilisateur ne peut accéder qu'aux applications autorisées après authentification. La clé WiFi peut rester simple (accès Internet uniquement) tandis que l'accès aux ressources M2L reste protégé par le broker ZTNA.

6.3 Les accès des prestataires et clubs extérieurs

Les clubs sportifs affiliés aux ligues accèdent au système de réservation via des codes Intranet diffusés par les ligues. Des prestataires externes (gardiennage, infographiste, société informatique) interviennent également dans les locaux. Ces accès représentent un vecteur d'attaque significatif :

- Des centaines de clubs peuvent avoir des codes d'accès Intranet — impossible à tracer individuellement
- Un code partagé par une ligue peut être diffusé sans contrôle à des tiers non autorisés
- Les prestataires avec accès physique (et WiFi) peuvent potentiellement atteindre le réseau interne

7. Proposition de Transition ZTNA pour la M2L

7.1 Prérequis identifiés

Avant toute migration, plusieurs conditions doivent être réunies dans le contexte M2L :

Prérequis	État actuel M2L	Action requise
Identity Provider (IdP)	⚠️ Absent (pas d'annuaire central pour les ligues)	Déployer Azure AD ou Okta — comptes par ligue
MFA pour tous les accès	❌ Non documenté	Activer Microsoft Authenticator ou équivalent
Inventaire des applications	⚠️ Partiel (intranet, FTP, mail identifiés)	Cartographier tous les accès distants
Agent sur les postes ligues	✅ Agent d'inventaire déjà en place via procédure M2L	Étendre à l'agent ZTNA (même démarche)
Conformité des postes	✅ Procédure d'intégration M2L existante	Lier la conformité à la politique ZTNA
Segmentation réseau	⚠️ Projet en cours (mentionné par M. Sapin)	ZTNA peut accélérer et structurer ce projet

7.2 Plan de migration en 5 phases

Phase	Actions concrètes pour la M2L	Durée
Phase 1 – Audit	Inventaire des accès distants actuels (réservation, FTP, digicode). Cartographie des flux réseau 172.16.0.0/16. Identification des risques inter-ligues.	1 mois
Phase 2 – Identité	Déploiement d'un IdP centralisé (ex : Azure AD gratuit jusqu'à 500 users). Création de comptes nominatifs par ligue. Activation MFA. Remplacement des codes Intranet partagés.	2 mois
Phase 3 – Pilote ZTNA	Migration du système de réservation des salles vers ZTNA (accès le plus ouvert aux clubs extérieurs). Test avec 2 à 3 ligues pilotes. Validation de la procédure de conformité des postes.	2 mois
Phase 4 – Extension	Migration du serveur FTP et de l'accès au serveur de configurations vers ZTNA. Déploiement à toutes les ligues. Formation de l'informaticien bénévole CROSL. Maintien du VPN IPsec pour les liens inter-bâtiments.	3 à 4 mois
Phase 5 – Segmentation	Mise en place de VLANs par ligue en cohérence avec les politiques ZTNA. Cloisonnement effectif du réseau (projet M. Sapin). Activation de la journalisation complète et tableaux de bord par ligue.	2 à 3 mois

7.3 Solution recommandée pour la M2L

Recommandation : Cloudflare Access (ZTNA)

Compte tenu des contraintes M2L (budget limité, 1 seul informaticien bénévole, 24 ligues indépendantes), Cloudflare Access est recommandé pour les raisons suivantes :

✅ Gratuit jusqu'à 50 utilisateurs (suffisant pour les premiers tests avec 2-3 ligues)

✅ Sans agent obligatoire côté utilisateur (mode service-based) → idéal pour les clubs extérieurs

✅ Interface d'administration simple → adaptée à un informaticien bénévole non dédié

✅ Intégration native avec Azure AD, Google, ou authentification par lien email (sans compte à créer)

✅ Journalisation automatique par utilisateur et par application

⚠️ Limite : au-delà de 50 utilisateurs, passage à un abonnement payant (environ 7€/user/mois)

8. Conclusion

L'analyse du contexte de la Maison des Ligues de Lorraine met en évidence que les limites du VPN traditionnel sont particulièrement critiques dans un environnement multi-tenant comme celui de la M2L. La cohabitation de 24 associations juridiquement indépendantes sur un réseau unique non segmenté constitue un risque que le VPN ne peut pas résoudre — et qu'il aggrave même, en donnant un accès réseau complet à quiconque s'authentifie.

Le ZTNA répond précisément aux besoins exprimés par M. Lucien Sapin : contrôle des accès, cloisonnement des structures, surveillance du parc. Il s'appuie de plus sur des éléments déjà en place à la M2L (procédure d'intégration des postes, agent d'inventaire) pour bâtir une architecture Zero Trust progressive et maîtrisée.

Pour un technicien réseau de profil SISR, la maîtrise du ZTNA — et sa mise en perspective avec le VPN traditionnel — est une compétence directement applicable dans des contextes réels tels que la M2L : infrastructures distribuées, accès multi-partenaires, contraintes budgétaires, et projets de segmentation réseau.

Synthèse finale – M2L et Zero Trust

🔴 Problème principal M2L : réseau plat 172.16.0.0/16 partagé entre 24 ligues indépendantes

🟠 Problème secondaire : accès Extranet non tracés (réservation, FTP, digicode) via codes partagés

🟢 Solution VPN : pertinent uniquement pour les liens inter-bâtiments (IPsec filaire A↔B↔C↔D)

🟢 Solution ZTNA : recommandée pour tous les accès distants applicatifs des ligues et des clubs

🟢 Priorité immédiate : déployer un IdP centralisé + MFA pour remplacer les codes Intranet partagés

🟢 Solution recommandée : Cloudflare Access (gratuit au démarrage, sans agent, simple à administrer)

9. Sources et Bibliographie

Documentation de référence

- NIST SP 800-207 – Zero Trust Architecture (août 2020) : https://csrc.nist.gov/publications/detail/sp/800-207/final
- Gartner – Magic Quadrant for Security Service Edge (SSE) 2024
- ANSSI – Guide de la sécurité des systèmes d'information : https://www.ssi.gouv.fr
- Directive NIS2 (UE 2022/2555) en vigueur depuis octobre 2024 : https://eur-lex.europa.eu

Solutions et éditeurs

- Cloudflare Access (ZTNA) : https://www.cloudflare.com/zero-trust/products/access/
- Zscaler Private Access (ZPA) : https://www.zscaler.com/products/zscaler-private-access
- Microsoft Azure AD + Entra : https://learn.microsoft.com/fr-fr/azure/active-directory/
- Google BeyondCorp Enterprise : https://cloud.google.com/beyondcorp-enterprise

Sources contextuelles

- Contexte AP BTS SIO 2ème année – Maison des Ligues de Lorraine (M2L) – Document Lycée Saint Rémi, Sources CERTA v1.1
- Forrester Research – John Kindervag, "No More Chewy Centers: Introducing The Zero Trust Model Of Information Security" (2010)